

Room Clarity Zoom Beta Security Evidence Packet

Prepared for Zoom Beta Security and Privacy Compliance Review - May 26, 2026

Recommended Attachments

- Room Clarity Zoom Beta Security Evidence Packet.pdf
- Room Clarity Privacy Policy.pdf
- Optional raw scan artifacts from `compliance/zoom-beta/artifacts/run-26339140824` if Zoom accepts non-PDF evidence.

Evidence Map

Item	Evidence
SSDLC	Included in this packet: Secure Software Development Lifecycle.
SAST results	CodeQL SAST, final successful run 26339140824, zero SARIF results.
DAST results	OWASP ZAP baseline against https://roomclarity.com , final successful run 26339140824.
Privacy Policy	Standalone PDF included; public page is https://roomclarity.com/privacy.html .
TLS 1.2+	<code>curl --tlsv1.2</code> check returned HTTP/2 200 and security headers.
Additional policies	Security, incident response, vulnerability management, and infrastructure/dependency management policies are included.

Executive Summary

Room Clarity is a Zoom app and HTTPS service for meeting decision support. The app processes meeting context, participant display names, transcript cues, generated decisions, risks, actions, and facilitation prompts when enabled by an authorized host. This packet provides the supporting evidence requested for Zoom Beta review.

Secure Software Development Lifecycle

Room Clarity uses a lightweight secure software development lifecycle appropriate for a beta Zoom app that processes meeting transcript data.

Scope

The SSDLC applies to application code, Zoom integration code, deployment configuration, dependencies, privacy-facing pages, and operational procedures for <https://roomclarity.com>.

Development Controls

- Changes are tracked in source control and reviewed before release.
- Product changes involving meeting transcripts, participant information, Zoom APIs, OAuth, RTMS, model providers, or dashboard access are treated as security-sensitive.
- Security-sensitive changes must identify affected data flows, credentials, access controls, logging behavior, and user-facing disclosures.
- Secrets are supplied through deployment environment variables or managed secret stores and are not committed to the repository.
- The service validates model output against structured constraints before incorporating it into meeting state.
- Transcript text is treated as untrusted input.

Security Checks

Before external beta release, the project runs:

- Dependency audit for production packages.
- SAST scan using CodeQL, Semgrep, or equivalent.
- DAST scan against the deployed HTTPS service using OWASP ZAP baseline or equivalent.
- Functional evals for transcript extraction behavior.
- Manual verification of security headers, webhook signature verification, access tokens, and admin route protections.

Release Controls

- Production deployments use Google Cloud Run and HTTPS.
- The public base URL is <https://roomclarity.com>.
- Required runtime secrets include Zoom OAuth credentials, Zoom webhook secret token, RTMS credentials if separate, model provider keys, and the Room Clarity admin token.
- Changes are verified after deployment using health checks, header checks, and targeted endpoint tests.

Data Protection Review

Meeting transcripts and generated meeting artifacts may contain confidential business, personnel, customer, financial, or legal information. Before external beta use, changes are reviewed for:

- Minimum necessary transcript processing.
- Retention and deletion behavior.
- Access control and token exposure.
- Logging of sensitive content.
- Third-party model provider handling.
- Participant and admin disclosures.

Evidence Location

Zoom Beta evidence is maintained in `compliance/zoom-beta/`. The security launch backlog is maintained in `docs/security-launch-plan.md`.

SAST, DAST, and Dependency Scan Results

Date checked: 2026-05-23

Final successful GitHub Actions run: 26339140824

Run URL:

<https://github.com/chrizbo/meeting-decision-maker/actions/runs/26339140824>

Dependency Audit

Command:

```
npm audit --omit=dev --json
```

Result:

```
{
  "auditReportVersion": 2,
  "vulnerabilities": {},
  "metadata": {
    "vulnerabilities": {
      "info": 0,
      "low": 0,
      "moderate": 0,
      "high": 0,
      "critical": 0,
      "total": 0
    },
    "dependencies": {
      "prod": 156,
      "dev": 0,
      "optional": 1,
      "peer": 0,
      "peerOptional": 0,
      "total": 156
    }
  }
}
```

Artifact: artifacts/run-26339140824/npm-audit-results/npm-audit-results.json

Production Dependency Inventory

Command:

```
npm ls --omit=dev --depth=0
```

Result:

```
meeting-decision-maker@0.1.0
├── @google-cloud/firestore@8.6.0
└── @zoom/rtms@1.1.0
```

Functional Eval Evidence

Command:

```
npm run eval
```

Result summary:

```
all cases
expected: 33
```

```
actual: 33
matched: 33
precision 100% · recall 100% · f1 100%
```

SAST

Status: completed.

The repository includes `.github/workflows/security-scans.yml`, which runs CodeQL SAST on pull requests, pushes to main, weekly schedule, and manual dispatch.

Final result from GitHub Actions run 26339140824:

```
CodeQL SAST: success
SARIF results: 0
```

Artifact: `artifacts/run-26339140824/codeql-sast-results/javascript.sarif`

Note: an earlier run found a reflected exception-text issue in API error responses. The app was patched to return fixed public error messages, and the final CodeQL run completed with zero results.

DAST

Status: completed.

The repository includes `.github/workflows/security-scans.yml`, which runs an OWASP ZAP baseline scan on manual workflow dispatch. The final scan used `https://roomclarity.com` as the `dast_target` input.

Final result from GitHub Actions run 26339140824:

```
OWASP ZAP DAST baseline: success
High alerts: 0
Medium alerts: 2
Low alerts: 5
Informational alerts: 4
```

Artifacts:

- `artifacts/run-26339140824/zap-baseline-results/report_html.html`
- `artifacts/run-26339140824/zap-baseline-results/report_md.md`
- `artifacts/run-26339140824/zap-baseline-results/report_json.json`

The medium findings are hardening warnings for CSP fallback directives and SRI on the Zoom Apps SDK script. These should be reviewed for compatibility with the Zoom Apps SDK before broad marketplace publication.

TLS Evidence

Date checked: 2026-05-23

Public service URL: <https://roomclarity.com>

TLS 1.2 Check

Command:

```
curl -sS -I --tlsv1.2 https://roomclarity.com/
```

Result:

```
HTTP/2 200
strict-transport-security: max-age=31536000; includeSubDomains
x-content-type-options: nosniff
content-security-policy: default-src 'self'; script-src 'self' https://appssdk.zoom.us; style-src 'self'; img-src 'se
referrer-policy: strict-origin-when-cross-origin
content-type: text/html; charset=utf-8
cache-control: no-store
server: Google Frontend
```

curl successfully connected with TLS 1.2 or higher and returned HTTP 200.

Health Check

Command:

```
curl -sS https://roomclarity.com/api/healthz
```

Result:

```
{"ok":true}
```

Security Policy

Purpose

Room Clarity protects meeting transcript content, participant metadata, generated meeting artifacts, Zoom integration credentials, and service administration controls.

Protected Data

Protected data includes:

- Meeting transcript text and cues.
- Participant names and meeting context.
- Generated decisions, risks, actions, and facilitation prompts.
- Zoom OAuth, webhook, and RTMS credentials.
- LLM provider API keys.
- Dashboard access tokens and admin tokens.

Access Control

- Production secrets are stored outside source control.
- Meeting dashboard access uses scoped access tokens.
- Administrative inspection routes require `ROOM_CLARITY_ADMIN_TOKEN`.
- Zoom webhook traffic is verified with HMAC signatures and timestamp freshness checks.
- Access control improvements for external launch are tracked in `docs/security-launch-plan.md`.

Application Security

- The service sends HSTS, Content Security Policy, `nosniff`, and referrer policy headers.
- Static files are served from the application directory with path normalization checks.
- Request bodies are size-limited.
- Selected public and inspection routes have rate limiting.
- Transcript text and model output are treated as untrusted input.

Logging

Operational logs should avoid raw transcript content, OAuth tokens, webhook secrets, RTMS secrets, dashboard tokens, and model provider keys. Logs should prefer event type, counts, status, and non-sensitive identifiers.

Review Cadence

This policy is reviewed before Zoom Beta resubmission, before marketplace publication, and after material changes to authentication, RTMS ingestion, transcript retention, or model-provider handling.

Incident Management and Response Policy

Purpose

This policy defines the response process for suspected or confirmed security, privacy, availability, or data handling incidents affecting Room Clarity.

Incident Examples

- Unauthorized access to meeting dashboard data.
- Exposure of meeting transcript content or generated artifacts.
- Compromise of Zoom, RTMS, LLM provider, cloud, or admin credentials.
- Webhook spoofing or replay attempts.
- Vulnerabilities that could permit data exfiltration, privilege escalation, or service abuse.
- Misconfigured retention or deletion behavior.

Response Roles

- Incident owner: coordinates investigation, containment, communication, remediation, and closure.
- Technical responder: reviews logs, code, deployment state, and access controls.
- Communications owner: prepares user, admin, provider, or marketplace communications when required.

For the current beta stage, these roles may be held by the same operator.

Response Process

- 1 Triage the report and assign severity.
- 2 Preserve relevant logs, timestamps, deployment versions, and affected routes.
- 3 Contain active exposure by disabling affected endpoints, rotating credentials, revoking tokens, or pausing beta access.
- 4 Investigate root cause and affected data.
- 5 Remediate code, configuration, credentials, or operational procedures.
- 6 Verify the fix with targeted tests and security checks.
- 7 Notify affected users, administrators, providers, or regulators when required.
- 8 Document timeline, impact, root cause, remediation, and follow-up tasks.

Severity Guidelines

- Critical: confirmed data exposure, credential compromise, or active exploitation.
- High: likely unauthorized access path or bypass of core security control.

- Medium: security weakness with limited exploitability or limited data exposure.
- Low: hardening issue, documentation gap, or defense-in-depth improvement.

Credential Rotation

If compromise is suspected, rotate affected Zoom credentials, webhook secret token, RTMS credentials, LLM provider keys, cloud credentials, and ROOM_CLARITY_ADMIN_TOKEN.

Vulnerability Management Procedures

Purpose

Room Clarity identifies, prioritizes, remediates, and verifies vulnerabilities in application code, dependencies, deployment configuration, and third-party integrations.

Inputs

- SAST results from CodeQL, Semgrep, or equivalent.
- DAST results from OWASP ZAP baseline or equivalent.
- `npm audit --omit=dev` dependency results.
- Cloud provider alerts.
- Zoom Marketplace review feedback.
- User, tester, or researcher reports.
- Manual review of security-sensitive changes.

Triage

Findings are assigned severity based on exploitability, affected data, user impact, and exposure.

- Critical: fix or mitigate before external beta access continues.
- High: fix before beta expansion or within seven days.
- Medium: fix within thirty days or before marketplace publication.
- Low: track for planned hardening.

Remediation

Remediation may include code changes, dependency updates, configuration changes, credential rotation, access revocation, additional tests, or documentation updates.

Verification

Each remediated vulnerability should be verified using the same class of evidence that found it when possible:

- Re-run SAST for static findings.
- Re-run DAST for deployed endpoint findings.
- Re-run dependency audit for vulnerable packages.
- Add targeted tests for regressions involving access control, webhook verification, token handling, parsing, or model-output validation.

Records

Security evidence and scan summaries for the Zoom Beta submission are stored in `compliance/zoom-beta/`. Product security backlog items are tracked in `docs/security-launch-plan.md`.

Infrastructure and Dependency Management Policy

Runtime Infrastructure

Room Clarity is deployed as a Node.js service on Google Cloud Run behind HTTPS. The public production hostname is `https://roomclarity.com`.

Runtime Configuration

Production configuration is provided through environment variables and managed secrets. Required values include:

- `ZOOM_CLIENT_ID`
- `ZOOM_CLIENT_SECRET`
- `ZOOM_REDIRECT_URI`
- `ZOOM_WEBHOOK_SECRET_TOKEN`
- `GEMINI_API_KEY` or `OPENAI_API_KEY`, depending on enabled model provider
- `PUBLIC_BASE_URL=https://roomclarity.com`
- `ROOM_CLARITY_ADMIN_TOKEN`
- `SESSION_STORE=firestore` when persistent session storage is enabled

Secrets must not be committed to source control.

Dependency Management

- Production dependencies are defined in `package.json` and locked in `package-lock.json`.
- Production installs use `npm ci --omit=dev` in the Docker build.
- Dependency audit evidence is collected with `npm audit --omit=dev --json`.
- Dependency changes should be reviewed for package reputation, maintenance status, license suitability, and transitive vulnerability impact.

Container Management

- The production image uses an official Node slim base image.
- The Docker build installs only production dependencies.
- The container exposes the Cloud Run port and starts `server.js`.
- Base image updates should be reviewed before beta expansion and marketplace publication.

Third-Party Services

Current service dependencies include:

- Zoom APIs, Zoom Apps SDK, and RTMS.

- Google Cloud Run.
- Google Firestore when persistent session storage is enabled.
- Gemini API or OpenAI API for model-backed analysis, depending on configuration.

Change Review

Infrastructure or dependency changes that affect credentials, transcript handling, webhook handling, OAuth, storage, logging, or model providers require security review before external beta release.